

Практическое занятие № 3
СПЕЦИАЛЬНЫЕ ТРЕБОВАНИЯ И РЕКОМЕНДАЦИИ ПО ТЕХНИЧЕСКОЙ
ЗАЩИТЕ КОНФИДЕНЦИАЛЬНОЙ ИНФОРМАЦИИ
(СТР-К)

*Утверждены приказом Председателя Гостехкомиссии России
от 30.08.2002 года № 282*

Цель занятия – изучение специальных требований и рекомендаций по технической защите конфиденциальной информации (СТР-К).

Время - 4 часа.

Учебные вопросы:

1. Общие положения СТР-К, основные понятия.
2. Организация работ по защите информации.
3. Стадии создания системы защиты информации.
4. Требования и рекомендации по защите речевой информации.
5. Требования и рекомендации по защите информации, обрабатываемой средствами вычислительной техники.
6. Рекомендации по обеспечению защиты информации, содержащейся в негосударственных информационных ресурсах, при взаимодействии абонентов с информационными сетями общего пользования.
7. Изучение образцов оформляемых документов при организации технической защиты информации.

**Методические указания студентам по подготовке и проведению
практического занятия**

При подготовке к занятию.

В период подготовки к практическому занятию студенты получают необходимую литературу в библиотеке университета или из открытых источников сети Интернет и изучают учебные материалы темы, используя литературу, а также конспект лекций. При подготовке к занятию уточнить содержание источников (литературы), рекомендуемой к данному занятию (пособия и учебники со сроком издания не более 5 лет). В ходе изучения материала на практическом занятии студентам рекомендуется ответить на контрольные вопросы, указанные в лекции и в методических рекомендациях по практическому занятию.

Порядок проведения занятия.

Во время проведения занятия преподаватель осуществляет опрос студентов и определяет их готовность к занятию. Затем студенты последовательно усваивают учебные вопросы, касающиеся технической защиты конфиденциальной информации, лично отрабатывают контрольные вопросы практического занятия. При необходимости сложные и малопонятные вопросы обсуждаются в группе под руководством преподавателя. По окончании занятия студенты оформляют отчет и представляют его преподавателю.

Задание 1. Анализ структуры и содержания СТР-К

Цель: ознакомиться с основными разделами документа СТР-К и определить его ключевые положения.

Задачи:

1. Изучить текст СТР-К (используя официальный сайт ФСТЭК или другие открытые источники).
2. Составить краткую схему структуры документа с указанием основных разделов и их содержания.

Результат:

- Схема структуры СТР-К.

Задание 2. Разработка модели угроз для объекта информатизации

Цель: научиться идентифицировать каналы утечки информации и источники угроз.

Задачи:

1. Выбрать условный объект информатизации (в качестве условного объекта информатизации может быть использована аудитория из лабораторных работ по дисциплине «Защита информации от утечки по техническим каналам» или организация, описание которой приведено в приложении 1).
2. На основе п.2.9 СТР-К определить возможные каналы утечки информации для выбранного объекта.
3. Составить таблицу угроз с указанием:
 - типа угрозы в соответствии с п.2.9 СТР-К,
 - источника угрозы,
 - возможных последствий.

Результат:

- Таблица угроз для выбранного объекта.
- Рекомендации по ликвидации выявленных угроз.

Задание 3. Проектирование системы защиты информации

Цель: применить требования СТР-К к проектированию системы защиты информации.

Задачи:

1. На основе СТР-К выделить этапы создания системы защиты информации.
2. Кратко описать работы, проводимые на каждой стадии создания СЗИ.
3. Разработать аналитическое обоснование необходимости создания системы защиты информации на выбранном объекте информатизации (Шаблон оформления аналитического обоснования необходимости создания системы защиты информации приведен в приложении 2).

Рекомендуемая структура аналитического обоснования:

- **Общие положения** – цель создания СЗИ, нормативная база, перечень привлекаемых организаций.
- **Описание систем и сетей и их характеристика как объектов защиты** – состав, архитектура, ПО, пользователи, анализ организационных мер, результаты классификации (уровень защищенности).

- **Возможные негативные последствия от реализации угроз безопасности информации** – указываются виды ущерба из Модели угроз.
 - **Возможные объекты воздействия угроз безопасности информации** – базы данных, АРМ, линии связи и т.д. - указываются из Модели угроз.
 - **Источники угроз безопасности информации** – виды нарушителей, их категории, возможности - указываются из Модели угроз.
 - **Способы реализации (возникновения) угроз безопасности информации** – методы и интерфейсы – указываются из Модели угроз.
 - **Актуальные угрозы безопасности информации** – перечень угроз с указанием тактик и техник – указываются из Модели угроз.
 - **Технические средства защиты информации (ТСЗИ), предлагаемые для использования** – перечень сертифицированных СЗИ.
 - **Обоснование необходимости привлечения специальных организаций** – лицензионные требования.
 - **Оценка материальных, трудовых и финансовых затрат на разработку и внедрение ТСЗИ** – таблицы стоимости оборудования, работ по установке, аттестации.
 - **Ориентировочные сроки разработки и внедрения ТСЗИ** – поэтапно.
 - **Перечень мероприятий по обеспечению конфиденциальности информации на стадии проектирования объекта информатизации** – основные организационные и технические меры.
4. Пример оформления аналитическое обоснование необходимости создания системы защиты информации приведен в приложении 3.

Результат:

- Поэтапный план создания системы защиты.
- Аналитическое обоснование необходимости создания системы защиты информации на выбранном объекте информатизации в соответствии с шаблоном.

Задание 4. Анализ документов по технической защите информации, разрабатываемых в соответствии с СТР-К

Цель: определить перечень документов, разрабатываемых в соответствии с СТР-К, при организации защиты информации в компании.

Задачи:

1. Проанализировать СТР-К, определить перечень эксплуатационной документации на систему защиты информации, разрабатываемой на каждой стадии создания СЗИ.
2. Представить результат анализа в виде таблицы следующего содержания (пример оформления таблицы представлен ниже):

Стадия создания СЗИ	Работы в соответствии с СТР-К	Основание	Наименование документа
1. Предпроектная стадия	Принятие решения о необходимости ЗИ	СТР-К, п. 3.8	ЛНА (Приказ), определяющий необходимость создания СЗИ

Результат:

- Перечень эксплуатационной документации на систему защиты информации, разрабатываемой на каждой стадии создания СЗИ в виде таблицы.

Требования к отчёту

Отчёт выполняется каждым студентом индивидуально. Работа должна быть оформлена в электронном виде в формате .doc и распечатана на листах формата А4. На титульном листе указываются: наименование учебного учреждения, наименование дисциплины, название и номер работы, вариант (при наличии), выполнил: фамилия, имя, отчество, группа, проверил: преподаватель ФИО.

Отчет должен содержать:

- титульный лист,
- цель практического занятия,
- отчёт по сайтам: Сайт ФСТЭК России, Сайт Федеральной службы по надзору в сфере связи, информационных технологий и массовых коммуникаций, иные открытые источники из сети Интернет;
- краткие ответы на контрольные вопросы.

Контрольные вопросы:

1. На что распространяются требования и рекомендации СТР-К?
2. Раскройте понятие ОТСС, ВТСС, целостность информации, СЗИ от НСД, доступ к информации, объект информатизации.
3. Что является защищаемыми объектами информатизации.
4. Какие каналы утечки и источники угроз безопасности информации выделяют при ведении переговоров и использовании технических средств для обработки и передачи информации?
5. Какие стадии создания системы защиты информации предусмотрены СТР-К?
6. Какие требования и рекомендации предъявляются к защите информации, циркулирующей в защищаемых помещениях?
7. В каких целях проводится классификация автоматизированных систем, в соответствии с каким руководящим документом проводятся мероприятия по классификации АС?
8. Как осуществляется защита информации при межсетевом взаимодействии?
9. Какие локально-нормативные акты, в соответствии с требованиями СТР-К, должны быть разработаны в компании при организации защиты информации?

Материально-техническое обеспечение.

Работа выполняется на ПЭВМ типа IBM PC с использованием стандартных функций ОС и дополнительных пакетов программ (Adobe Acrobat Reader ver. 3.0 или выше, либо аналогичные программы для просмотра файлов с расширением pdf).

Литература:

1. Специальные требования и рекомендации по технической защите

конфиденциальной информации (СТР-К) –

https://disk.yandex.ru/i/JwAx_2qk4FQ4HA

2. Кормановский Н.С., Михайличенко С.В., Савков С.В. «Организационно-правовое и методическое обеспечение информационной безопасности»/ Уч. Пособие. – СПб: НИУ ИТМО, 2013.
3. Стрельцов А.А. Организационно-правовое обеспечение информационной безопасности: уч. Пособие для студентов ВУЗ – М. Издательский центр «Академия», 2008.
4. Официальный сайт ФСТЭК. <https://fstec.ru/>

Исходные данные для разработки аналитического обоснования

Информационная система персональных данных «Кадровый учет»

Описание информационной системы персональных данных организации ИСПДн «Кадровый учет»:

Организация: АО УК «Чистый дом», организация осуществляет деятельность по управлению многоквартирными домами, предоставлению жилищно-коммунальных услуг и иные виды деятельности, связанные с эксплуатацией жилищного фонда.

Описание ИСПДн:

Состав:

Персональные данные сотрудников организации:

- фамилия, имя, отчество;
- дата и место рождения;
- пол;
- сведения об образовании;
- сведения о предыдущем месте работы;
- адреса регистрации и фактического проживания;
- номера контактных телефонов;
- индивидуальный номер налогоплательщика;
- номер страхового свидетельства пенсионного страхования;
- номер полиса обязательного медицинского страхования;
- данные водительского удостоверения.

В информационной системе одновременно обрабатываются данные 98 субъектов персональных данных (сотрудников) в пределах Организации.

2. Имеется три автоматизированных рабочих места (АРМ) пользователей, сетевой принтер, сервер, коммутационное оборудование.

Топология: АРМ и сервер составляют сегмент корпоративной вычислительной сети (см. схему).

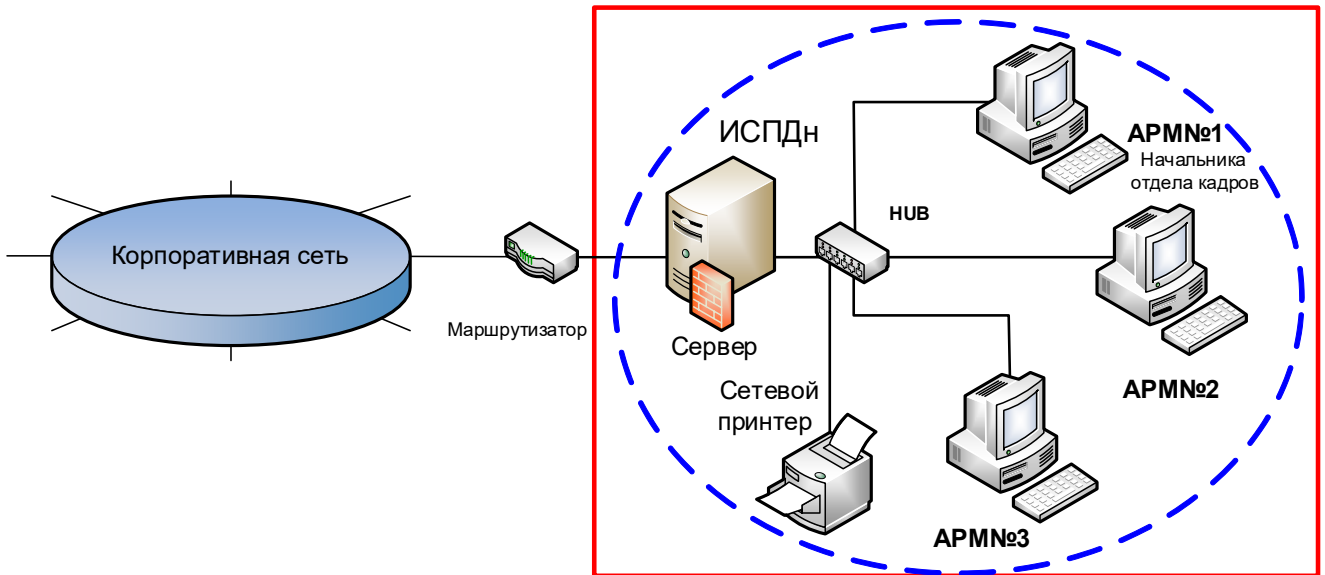


Схема ИСПД АО УК «Чистый дом»

Корпоративная сеть Организации не имеет подключение к сетям связи общего пользования и сетям международного информационного обмена.

В состав каждого АРМ входят два жёстких диска, на первом установлена операционная система, прикладное программное обеспечение и общедоступная справочная информация, на втором - информация, составляющая персональные данные сотрудников Организации.

1. Комплект АРМ № 1-3 (см. схему):

- системный блок CityTime № JFBNCGRHDBG01-03,
- монитор Samsung N710 – серийный номер KBMHDFGFD01-03,
- клавиатура Genius серийный номер WESDC01-03,
- графический манипулятор (мышь) Genius серийный номер DSDA01-03.

Состав ПО для обработки ПД:

- Клиентская часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОПИ) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

- Диспетчер печати.

2. В состав сервера входят три жестких диска, на первом установлена операционная система, прикладное программное обеспечение, второй и третий объединены в RAID массив, в котором хранится информация, составляющая персональные данные сотрудников Организации.

Комплект сервера:

- системный блок CityTime Prof № SDHBKYDHG04,
- монитор Samsung N710 – серийный номер JDHDNGHD04,
- клавиатура Genius серийный номер DGFU04,
- графический манипулятор Genius серийный номер HBDR04.

Состав ПО для обработки ПД:

- Серверная часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОПИ) в соответствии

с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

2. Диспетчер печати.

Сервер и коммуникационное оборудование установлены в типовой стойке.

Сетевой принтер HP LaserJet P2015 серийный номер DEFVBG.

Коммутатор: Коммутатор Cisco WS-C2960CX-8TC-L.

Маршрутизатор: Маршрутизатор Cisco Small Business RV340-K8-RU.

1. Технология обработки персональных данных:

Обработка персональных данных сотрудников включает весь перечень действий, включая сбор, запись, систематизацию, накопление, хранение, уточнение (обновление, изменение), извлечение, использование, передачу (распространение, предоставление, доступ), обезличивание, блокирование, удаление, уничтожение персональных данных.

К работе на АРМ допущены сотрудники отдела кадров и заместитель директора.

Полный доступ ко всей информации на АРМ и сервере имеют заместитель директора и начальник отдела кадров.

Сотрудники отдела кадров имеют полный доступ только к каталогу «Личные дела», размещённой на диске №2 своего АРМ, и только на чтение информации из каталога «Личные дела» на сервере.

Системный администратор сегмента сети не имеет доступа к информации, составляющей персональные данные. Имеет права на установку, настройку программного обеспечения, программных (программно-аппаратных) средств защиты сервера и АРМ № 1-3.

Режим работы - одновременный.

Расположение: АО УК «Чистый дом», г. Ростов-на-Дону, ул. Строителей, дом № 15, офис 306, расположено на третьем этаже 3-х этажного здания. На 1-ом и 2-ем этажах расположены сторонние организации. Имеется общая охраняемая территория. Допуск посторонних лиц и автомашин только с согласия руководителя Организации и руководителей сторонних организаций. Доступ в помещение ограничен распорядительными актами Организации и автоматизированной системой контроля и управления доступа. Перечень сотрудников, имеющих доступ к конфиденциальной информации, определен приказом руководителя АО УК «Чистый дом».

Контролируемая зона (КЗ) ЗП для носимых ТСП проходит по ограждающим конструкциям третьего этажа, за исключением лестницы на верхние этажи. Исследуемое ЗП - переговорная – не граничит с КЗ для возимых ТСП, а для носимых ТСП граничит по потолку. КЗ для возимых ТСП проходит по периметру внешнего ограждения (забора) организации. Границей КЗ для стационарных ТСП является: с севера – жилое здание (расстояние 250 м.), с юга - территория организации ООО «Интеко» (расстояние 189 м.), с запада – здание бассейна «Волна» (расстояние 176 м.), с востока - жилое здание, находящееся через парк (расстояние 1020 м.). Средства звукоусиления отсутствуют.

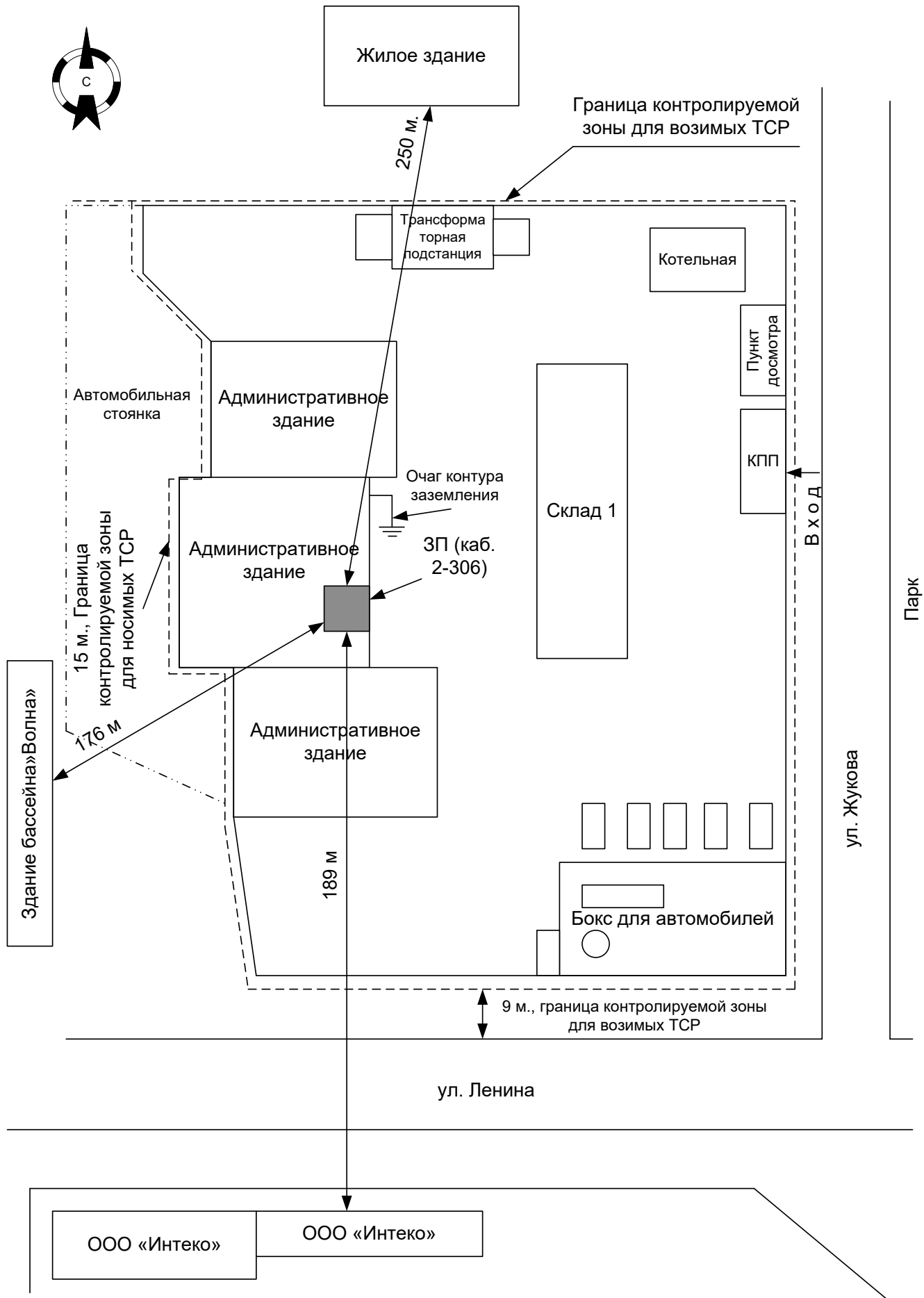


Схема границ контролируемых зон АО УК «Чистый дом»

Приложение 2**Шаблон аналитического обоснования необходимости создания
системы защиты информации на объекте информатизации****УТВЕРЖДАЮ¹**

(должность руководителя организации)

(подпись)

« ____ » _____ 202 ____ г.

**Аналитическое обоснование необходимости создания системы защиты информации на
объекте информатизации ИСПДн «Кадровый учет»**

*(наименование ИСПДн)***СОГЛАСОВАНО**

« ____ » _____ 202 ____ г.**СОГЛАСОВАНО**

« ____ » _____ 202 ____ г.

202_ г.

¹ Аналитическое обоснование подписывается руководителем предпроектного обследования, согласовывается с главным конструктором (должностным лицом, обеспечивающим научно-техническое руководство создания объекта информатизации), руководителем службы безопасности и утверждается руководителем предприятия-заказчика. Перечень сведений конфиденциального характера составляется заказчиком объекта информатизации и утверждается его руководителем.

1. Термины и определения

1. **Автоматизированное рабочее место** – программно-технический комплекс, предназначенный для автоматизированной деятельности определенного вида.
2. **Администратор автоматизированной системы** – лицо, ответственное за функционирование автоматизированной информационной системы в установленном штатном режиме работы.
3. **Администратор защиты (безопасности) информации** – лицо, ответственное за защиту автоматизированной информационной системы от несанкционированного доступа к информации.
4. **Аутентификация** – проверка принадлежности субъекту доступа предъявленного им идентификатора.
5. **Безопасность персональных данных** – состояние защищенности персональных данных, характеризуемое способностью пользователей, технических средств и информационных технологий обеспечить конфиденциальность, целостность и доступность персональных данных при их обработке в информационных системах персональных данных.
6. **Блокирование персональных данных** – временное прекращение сбора, систематизации, накопления, использования, распространения, персональных данных, в том числе их передачи.
7. **Вирус (компьютерный, программный)** – исполняемый программный код или интерпретируемый набор инструкций, обладающий свойствами несанкционированного распространения и самовоспроизведения. Созданные дубликаты компьютерного вируса не всегда совпадают с оригиналом, но сохраняют способность к дальнейшему распространению и самовоспроизведению.
8. **Вредоносная программа** – программа, предназначенная для осуществления несанкционированного доступа и (или) воздействия на персональные данные или ресурсы информационной системы персональных данных.
9. **Вспомогательные технические средства и системы** – технические средства и системы, не предназначенные для передачи, обработки и хранения персональных данных, устанавливаемые совместно с техническими средствами и системами, предназначенными для обработки персональных данных или в помещениях, в которых установлены информационные системы персональных данных.
10. **Доступ к информации** – возможность получения информации и ее использования.
11. **Защищаемая информация** – информация, являющаяся предметом собственности и подлежащая защите в соответствии с требованиями правовых документов или требованиями, устанавливаемыми собственником информации.
12. **Идентификация** – присвоение субъектам и объектам доступа идентификатора и (или) сравнение предъявляемого идентификатора с перечнем присвоенных идентификаторов.
13. **Использование персональных данных** – действия (операции) с персональными данными, совершаемые оператором в целях принятия решений или совершения иных действий, порождающих юридические последствия в отношении субъекта персональных данных или других лиц либо иным образом затрагивающих права и свободы субъекта персональных данных или других лиц.
14. **Источник угрозы безопасности информации** – субъект доступа, материальный объект или физическое явление, являющиеся причиной возникновения угрозы безопасности информации.
15. **Конфиденциальность персональных данных** – обязательное для соблюдения оператором или иным получившим доступ к персональным данным лицом требование не допускать их распространение без согласия субъекта персональных данных или наличия иного законного основания.
16. **Межсетевой экран** – локальное (однокомпонентное) или функционально-распределенное программное (программно-аппаратное) средство (комплекс), реализующее контроль за информацией, поступающей в информационную систему персональных данных и (или) выходящей из информационной системы.

17. **Недекларированные возможности** – функциональные возможности средств вычислительной техники, не описанные или не соответствующие описанным в документации, при использовании которых возможно нарушение конфиденциальности, доступности или целостности обрабатываемой информации.

18. **Несанкционированный доступ (несанкционированные действия)** – доступ к информации или действия с информацией, нарушающие правила разграничения доступа с использованием штатных средств, предоставляемых информационными системами персональных данных.

19. **Носитель информации** – физическое лицо или материальный объект, в том числе физическое поле, в котором информация находит свое отражение в виде символов, образов, сигналов, технических решений и процессов, количественных характеристик физических величин.

20. **Обезличивание персональных данных** – действия, в результате которых становится невозможным без использования дополнительной информации определить принадлежность персональных данных конкретному субъекту персональных данных.

21. **Обработка персональных данных** – действия (операции) с персональными данными, включая сбор, систематизацию, накопление, хранение, уточнение (обновление, изменение), использование, распространение (в том числе передачу), обезличивание, блокирование, уничтожение персональных данных.

22. **Общедоступные персональные данные** – персональные данные, доступ неограниченного круга лиц к которым предоставлен с согласия субъекта персональных данных или на которые в соответствии с федеральными законами не распространяется требование соблюдения конфиденциальности.

23. **Объект защиты информации** - информация, или носитель информации, или информационный процесс, которые необходимо защищать в соответствии с поставленной целью защиты информации.

24. **Оператор** – государственный орган, муниципальный орган, юридическое или физическое лицо, организующее и (или) осуществляющее обработку персональных данных, а также определяющие цели и содержание обработки персональных данных.

25. **Перехват (информации)** – неправомерное получение информации с использованием технического средства, осуществляющего обнаружение, прием и обработку информативных сигналов.

26. **Персональные данные** – любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу (субъекту персональных данных).

27. **Пользователь информационной системы персональных данных** – лицо, участвующее в функционировании информационной системы персональных данных или использующее результаты ее функционирования.

28. **Правила разграничения доступа** – совокупность правил, регламентирующих права доступа субъектов доступа к объектам доступа.

29. **Раскрытие персональных данных** – умышленное или случайное нарушение конфиденциальности персональных данных.

30. **Распространение персональных данных** – действия, направленные на передачу персональных данных определенному кругу лиц (передача персональных данных) или на ознакомление с персональными данными неограниченного круга лиц, в том числе обнародование персональных данных в средствах массовой информации, размещение в информационно-телекоммуникационных сетях или предоставление доступа к персональным данным каким-либо иным способом.

31. **Ресурс информационной системы** – именованный элемент системного, прикладного или аппаратного обеспечения функционирования информационной системы.

32. **Система** – совокупность взаимосвязанных и взаимодействующих элементов.

33. **Средства защиты информации** – технические, программные средства, вещества и (или) материал, предназначенные или используемые для защиты информации.

34. **Средства криптографической защиты информации** – аппаратные, программные и программно-аппаратные средства, системы и комплексы, реализующие алгоритмы

криптографического преобразования информации и предназначенные для защиты информации при передаче по каналам связи и (или) для защиты информации от несанкционированного доступа при ее обработке и хранении.

35. Специальные категории персональных данных – персональные данные, касающиеся расовой, национальной принадлежности, политических взглядов, религиозных или философских убеждений, состояния здоровья и интимной жизни субъекта персональных данных.

36. Средства вычислительной техники – совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем.

37. Субъект доступа (субъект) – лицо или процесс, действия которого регламентируются правилами разграничения доступа.

38. Технические средства информационной системы персональных данных – средства вычислительной техники, информационно-вычислительные комплексы и сети, средства и системы передачи, приема и обработки персональных данных (средства и системы звукозаписи, звукоусиления, звуковоспроизведения, переговорные и телевизионные устройства, средства изготовления, тиражирования документов и другие технические средства обработки речевой, графической, видео- и буквенно-цифровой информации), программные средства (операционные системы, системы управления базами данных и т.п.)

39. Угроза безопасности информации – совокупность условий и факторов, создающих потенциальную или реальную существующую опасность, связанную с утечкой информации и/или непреднамеренными воздействиями на нее.

40. Учетная запись пользователя – набор данных, однозначно идентифицирующих пользователя в системе, совокупность прав и привилегий доступа к объектам и набор квот системных ресурсов.

41. Угрозы безопасности персональных данных – совокупность условий и факторов, создающих опасность несанкционированного, в том числе случайного, доступа к персональным данным, результатом которого может стать уничтожение, изменение, блокирование, копирование, распространение персональных данных, а также иных несанкционированных действий при их обработке в информационной системе персональных данных.

42. Уничтожение персональных данных – действия, в результате которых невозможно восстановить содержание персональных данных в информационной системе персональных данных или в результате которых уничтожаются материальные носители персональных данных.

43. Уязвимость – слабость в средствах защиты, которую можно использовать для нарушения системы или содержащейся в ней информации.

44. Целостность информации – способность средства вычислительной техники или автоматизированной системы обеспечивать неизменность информации в условиях случайного и/или преднамеренного искажения (разрушения).

2. Принятые сокращения

ABC	–	антивирусные средства
АРМ	–	автоматизированное рабочее место
АС	–	автоматизированная система
ГИС	–	государственная информационная система
ГОСТ	–	государственный стандарт
ИБ	–	информационная безопасность
ИС	–	информационная система, обрабатывающая информацию
КЗ	–	контролируемая зона
ИТ	–	информационные технологии
ЛВС	–	локальная вычислительная сеть
НДВ	–	не декларированные возможности
НЖМД	–	накопитель на жестких магнитных дисках
НСД	–	несанкционированный доступ
ОЗУ	–	оперативное запоминающее устройство

ОПО	–	общесистемное программное обеспечение
ОС	–	операционная система
ОТСС	–	основные технические средства и системы
ПДн	–	персональные данные
ПК	–	программный комплекс
ПО	–	программное обеспечение
ПС	–	программные средства
ПТС	–	программно-технические средства
ПЭВМ	–	персональная электронно-вычислительная машина
РД	–	руководящий документ
СВТ	–	средства вычислительной техники
СЗИ	–	система защиты информации
СКЗИ	–	средства криптографической защиты информации
СПО	–	специальное программное обеспечение
СрЗИ	–	средства защиты информации
ТЗ	–	техническое задание
ТС	–	технические средства
ТП	–	технический проект
ФСБ	–	Федеральная служба безопасности
ФСТЭК	–	Федеральная служба технического и экспортного контроля

3. Общие положения

Необходимостью создания ТЗКИ в ИСПДн «Кадровый учет» АО УК «Чистый дом» является обеспечение защиты информации при ее обработке в информационной системе.

СЗИ представляет собой совокупность организационных и технических мер, направленных на предотвращение неправомерного или случайного доступа к защищаемой информации, уничтожения, изменения, блокирования, копирования, распространения, а также иных неправомерных действий с ней.

Система защиты информации должна:

- защищать ИС от вмешательства посторонних лиц в процесс её функционирования (возможность использования ИС и доступ к её ресурсам должны иметь только зарегистрированные установленным порядком пользователи);
- предоставлять доступ конкретным пользователям ИС только к тем ресурсам ИС, к которым он необходим для выполнения своих служебных обязанностей, то есть защищать от несанкционированного доступа: к информации, обрабатываемой в ИС, средствам вычислительной техники, аппаратным и программным средствам защиты;
- регистрировать действия пользователей при использовании защищаемых ресурсов ИС в системных журналах и анализировать содержимое этих журналов с целью контроля корректности действий пользователей;
- контролировать целостность среды исполнения программ и ее восстановление в случае нарушения;
- защищать от несанкционированной модификации и контролировать целостность программных средств, а также обеспечить защиту системы от внедрения несанкционированных программ;
- защищать информацию, хранимую, обрабатываемую и передаваемую по каналам связи, от несанкционированного разглашения или искажения;
- своевременно выявлять источники угроз безопасности информации, причины и условия, способствующие их появлению, создавать механизмы оперативного реагирования на угрозы;
- создавать условия для минимизации наносимого ущерба неправомерными действиями физических и юридических лиц, уменьшать негативное влияние и ликвидировать последствия нарушения безопасности информации.

Для аналитического обоснования необходимости создания СЗИ использовалась Модель угроз безопасности информации для ИСПДн «Кадровый учет» АО УК «Чистый дом», разработанная на основании следующих документов:

- ГОСТ Р 51275-2006 Защита информации. Объект информатизации. Факторы, воздействующие на информацию;
- «Базовая модель угроз безопасности персональных данных при их обработке в информационных системах персональных данных», утвержденная Заместителем директора ФСТЭК России 15 февраля 2008 г;
- «Методика оценки угроз безопасности информации», утвержденная Заместителем директора ФСТЭК России 5 февраля 2021 г.

Для разработки модели угроз безопасности информации на договорной основе была привлечена организация - Закрытое акционерное общество «Центр безопасности информационных технологий» (ЗАО «ЦБИТ»), Регистрационный номер лицензии - Л024-00107-00/00583574 от 10.06.2016), совместно с начальником отдела по информационной безопасности (ИБ) АО УК «Чистый дом».

4. Описание систем и сетей и их характеристика как объектов защиты²

4.1 Архитектура и схема подключений информационной системы

4.2 Описание процессов передачи информации

4.3 Перечень программных средств, используемых для обработки персональных данных в ИСПДн «Кадровый учет» АО УК «Чистый дом»

4.4 Перечень структурных подразделений работающих с БД ИСПДн «Кадровый учет» АО УК «Чистый дом»

4.5 Анализ организационных мер защиты ИСПДн

4.6 Анализ технологического процесса обработки информации, реализованного в информационной системе

² Для описания п.4-9 используйте материалы Модели угроз ПДн, разработанные на ранее проводимых занятиях.

На предпроектной стадии по обследованию объекта информатизации:

- устанавливается необходимость обработки (обсуждения) конфиденциальной информации на данном объекте информатизации;
- определяется перечень сведений конфиденциального характера, подлежащих защите от утечки по техническим каналам;
- определяются (уточняются) угрозы безопасности информации и модель вероятного нарушителя применительно к конкретным условиям функционирования;
- определяются условия расположения объектов информатизации относительно границ КЗ;
- определяются конфигурация и топология ИСПДн и систем связи в целом и их отдельных компонент, физические, функциональные и технологические связи как внутри этих систем, так и с другими системами различного уровня и назначения;
- определяются технические средства и системы, предполагаемые к использованию в разрабатываемой ИС и системах связи, условия их расположения, общесистемные и прикладные программные средства, имеющиеся на рынке и предлагаемые к разработке;
- определяются режимы обработки информации в ИС в целом и в отдельных компонентах;
- **определяется класс защищенности ИСПДн;**
- определяется степень участия персонала в обработке (обсуждении, передаче, хранении) информации, характер их взаимодействия между собой и со службой безопасности;
- определяются мероприятия по обеспечению конфиденциальности информации в процессе проектирования объекта информатизации.

4.7 Результаты классификации ИСПДн «Кадровый учет» АО УК «Чистый дом»

- 5. Возможные негативные последствия от реализации (возникновения) угроз безопасности информации**
- 6. Возможные объекты воздействия угроз безопасности информации**
- 7. Источники угроз безопасности информации**
- 8. Способы реализации (возникновения) угроз безопасности информации**
- 9. Актуальные угрозы безопасности информации**
- 10. ТСЗИ предлагаемые для использования ИСПДн**
- 11. Обоснование необходимости привлечения специальных организаций**
- 12. Оценка материальных, трудовых и финансовых затрат на разработку и внедрение ТСЗИ**
- 13. Ориентировочные сроки разработки и внедрения ТСЗИ**
- 14. Перечень мероприятий по обеспечению конфиденциальности информации на стадии проектирования объекта информатизации**

Руководитель предпроектного обследования _____ И.О. Фамилия

**Пример оформления аналитического обоснования необходимости
создания системы защиты информации на объекте информатизации**

УТВЕРЖДАЮ

Директор АО УК «Чистый дом»

И.И. Иванов

(подпись)

«15» мая 2026 г.

**Аналитическое обоснование необходимости создания системы защиты информации на
объекте информатизации ИСПДн «Кадровый учет»**

СОГЛАСОВАНО

Начальник отдела ИБ
АО УК «Чистый дом»

П.А. Петров

« ____ » _____ 202 ____ г.

СОГЛАСОВАНО

Главный конструктор СЗИ

С.С. Сидоров

« ____ » _____ 202 ____ г.

2026 г.

1. Термины и определения.....
2. Принятые сокращения.....
3. Общие положения.....
4. Описание систем и сетей и их характеристика как объектов защиты.....
- 4.1 Архитектура и схема подключений информационной системы.....
- 4.2 Описание процессов передачи информации.....
- 4.3 Перечень программных средств, используемых для обработки персональных данных в ИСПДн «Кадровый учет» АО УК «Чистый дом»
- 4.4 Перечень структурных подразделений работающих с БД ИСПДн «Кадровый учет»
АО УК «Чистый дом».....
- 4.5 Анализ организационных мер защиты ИСПДн «Кадровый учет» АО УК «Чистый дом».....
- 4.6 Анализ технологического процесса обработки информации, реализованного в информационной системе.....
- 4.7 Результаты классификации ИСПДн «Кадровый учет» АО УК «Чистый дом»...
5. Возможные негативные последствия от реализации (возникновения) угроз безопасности информации
6. Возможные объекты воздействия угроз безопасности информации.....
7. Источники угроз безопасности информации.....
8. Способы реализации (возникновения) угроз безопасности информации.....
9. Актуальные угрозы безопасности информации.....
10. ТСЗИ предлагаемые для использования ИСПДн.....
11. Обоснование необходимости привлечения специальных организаций.....
12. Оценка материальных, трудовых и финансовых затрат на разработку и внедрение ТСЗИ.....
13. Ориентировочные сроки разработки и внедрения ТСЗИ.....
14. Перечень мероприятий по обеспечению конфиденциальности информации на стадии проектирования объекта информатизации.....

1. Термины и определения

1. **Автоматизированное рабочее место** – программно-технический комплекс, предназначенный для автоматизированной деятельности определенного вида.
2. **Администратор автоматизированной системы** – лицо, ответственное за функционирование автоматизированной информационной системы в установленном штатном режиме работы.
3. **Администратор защиты (безопасности) информации** – лицо, ответственное за защиту автоматизированной информационной системы от несанкционированного доступа к информации.
4. **Аутентификация** – проверка принадлежности субъекту доступа предъявленного им идентификатора.
5. **Безопасность персональных данных** – состояние защищенности персональных данных, характеризуемое способностью пользователей, технических средств и информационных технологий обеспечить конфиденциальность, целостность и доступность персональных данных при их обработке в информационных системах персональных данных.
6. **Блокирование персональных данных** – временное прекращение сбора, систематизации, накопления, использования, распространения, персональных данных, в том числе их передачи.
7. **Вирус (компьютерный, программный)** – исполняемый программный код или интерпретируемый набор инструкций, обладающий свойствами несанкционированного распространения и самовоспроизведения. Созданные дубликаты компьютерного вируса не всегда совпадают с оригиналом, но сохраняют способность к дальнейшему распространению и самовоспроизведению.
8. **Вредоносная программа** – программа, предназначенная для осуществления несанкционированного доступа и (или) воздействия на персональные данные или ресурсы информационной системы персональных данных.
9. **Вспомогательные технические средства и системы** – технические средства и системы, не предназначенные для передачи, обработки и хранения персональных данных, устанавливаемые совместно с техническими средствами и системами, предназначенными для обработки персональных данных или в помещениях, в которых установлены информационные системы персональных данных.
10. **Доступ к информации** – возможность получения информации и ее использования.
11. **Защищаемая информация** – информация, являющаяся предметом собственности и подлежащая защите в соответствии с требованиями правовых документов или требованиями, устанавливаемыми собственником информации.
12. **Идентификация** – присвоение субъектам и объектам доступа идентификатора и (или) сравнение предъявляемого идентификатора с перечнем присвоенных идентификаторов.
13. **Использование персональных данных** – действия (операции) с персональными данными, совершаемые оператором в целях принятия решений или совершения иных действий, порождающих юридические последствия в отношении субъекта персональных данных или других лиц либо иным образом затрагивающих права и свободы субъекта персональных данных или других лиц.
14. **Источник угрозы безопасности информации** – субъект доступа, материальный объект или физическое явление, являющиеся причиной возникновения угрозы безопасности информации.
15. **Конфиденциальность персональных данных** – обязательное для соблюдения оператором или иным получившим доступ к персональным данным лицом требование не допускать их распространение без согласия субъекта персональных данных или наличия иного законного основания.
16. **Межсетевой экран** – локальное (однокомпонентное) или функционально-распределенное программное (программно-аппаратное) средство (комплекс), реализующее контроль за информацией, поступающей в информационную систему персональных данных и (или) выходящей из информационной системы.

17. **Недекларированные возможности** – функциональные возможности средств вычислительной техники, не описанные или не соответствующие описанным в документации, при использовании которых возможно нарушение конфиденциальности, доступности или целостности обрабатываемой информации.

18. **Несанкционированный доступ (несанкционированные действия)** – доступ к информации или действия с информацией, нарушающие правила разграничения доступа с использованием штатных средств, предоставляемых информационными системами персональных данных.

19. **Носитель информации** – физическое лицо или материальный объект, в том числе физическое поле, в котором информация находит свое отражение в виде символов, образов, сигналов, технических решений и процессов, количественных характеристик физических величин.

20. **Обезличивание персональных данных** – действия, в результате которых становится невозможным без использования дополнительной информации определить принадлежность персональных данных конкретному субъекту персональных данных.

21. **Обработка персональных данных** – действия (операции) с персональными данными, включая сбор, систематизацию, накопление, хранение, уточнение (обновление, изменение), использование, распространение (в том числе передачу), обезличивание, блокирование, уничтожение персональных данных.

22. **Общедоступные персональные данные** – персональные данные, доступ неограниченного круга лиц к которым предоставлен с согласия субъекта персональных данных или на которые в соответствии с федеральными законами не распространяется требование соблюдения конфиденциальности.

23. **Объект защиты информации** - информация, или носитель информации, или информационный процесс, которые необходимо защищать в соответствии с поставленной целью защиты информации.

24. **Оператор** – государственный орган, муниципальный орган, юридическое или физическое лицо, организующее и (или) осуществляющее обработку персональных данных, а также определяющие цели и содержание обработки персональных данных.

25. **Перехват (информации)** – неправомерное получение информации с использованием технического средства, осуществляющего обнаружение, прием и обработку информативных сигналов.

26. **Персональные данные** – любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу (субъекту персональных данных).

27. **Пользователь информационной системы персональных данных** – лицо, участвующее в функционировании информационной системы персональных данных или использующее результаты ее функционирования.

28. **Правила разграничения доступа** – совокупность правил, регламентирующих права доступа субъектов доступа к объектам доступа.

29. **Раскрытие персональных данных** – умышленное или случайное нарушение конфиденциальности персональных данных.

30. **Распространение персональных данных** – действия, направленные на передачу персональных данных определенному кругу лиц (передача персональных данных) или на ознакомление с персональными данными неограниченного круга лиц, в том числе обнародование персональных данных в средствах массовой информации, размещение в информационно-телекоммуникационных сетях или предоставление доступа к персональным данным каким-либо иным способом.

31. **Ресурс информационной системы** – именованный элемент системного, прикладного или аппаратного обеспечения функционирования информационной системы.

32. **Система** – совокупность взаимосвязанных и взаимодействующих элементов.

33. **Средства защиты информации** – технические, программные средства, вещества и (или) материал, предназначенные или используемые для защиты информации.

34. **Средства криптографической защиты информации** – аппаратные, программные и программно-аппаратные средства, системы и комплексы, реализующие алгоритмы

криптографического преобразования информации и предназначенные для защиты информации при передаче по каналам связи и (или) для защиты информации от несанкционированного доступа при ее обработке и хранении.

35. Специальные категории персональных данных – персональные данные, касающиеся расовой, национальной принадлежности, политических взглядов, религиозных или философских убеждений, состояния здоровья и интимной жизни субъекта персональных данных.

36. Средства вычислительной техники – совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем.

37. Субъект доступа (субъект) – лицо или процесс, действия которого регламентируются правилами разграничения доступа.

38. Технические средства информационной системы персональных данных – средства вычислительной техники, информационно-вычислительные комплексы и сети, средства и системы передачи, приема и обработки персональных данных (средства и системы звукозаписи, звукоусиления, звуковоспроизведения, переговорные и телевизионные устройства, средства изготовления, тиражирования документов и другие технические средства обработки речевой, графической, видео- и буквенно-цифровой информации), программные средства (операционные системы, системы управления базами данных и т.п)

39. Угроза безопасности информации – совокупность условий и факторов, создающих потенциальную или реальную существующую опасность, связанную с утечкой информации и/или непреднамеренными воздействиями на нее.

40. Учетная запись пользователя – набор данных, однозначно идентифицирующих пользователя в системе, совокупность прав и привилегий доступа к объектам и набор квот системных ресурсов.

41. Угрозы безопасности персональных данных – совокупность условий и факторов, создающих опасность несанкционированного, в том числе случайного, доступа к персональным данным, результатом которого может стать уничтожение, изменение, блокирование, копирование, распространение персональных данных, а также иных несанкционированных действий при их обработке в информационной системе персональных данных.

42. Уничтожение персональных данных – действия, в результате которых невозможно восстановить содержание персональных данных в информационной системе персональных данных или в результате которых уничтожаются материальные носители персональных данных.

43. Уязвимость – слабость в средствах защиты, которую можно использовать для нарушения системы или содержащейся в ней информации.

44. Целостность информации – способность средства вычислительной техники или автоматизированной системы обеспечивать неизменность информации в условиях случайного и/или преднамеренного искажения (разрушения).

2. Принятые сокращения

АВС	–	антивирусные средства
АРМ	–	автоматизированное рабочее место
АС	–	автоматизированная система
ГИС	–	государственная информационная система
ГОСТ	–	государственный стандарт
ИБ	–	информационная безопасность
ИС	–	информационная система, обрабатывающая информацию
КЗ	–	контролируемая зона
ИТ	–	информационные технологии
ЛВС	–	локальная вычислительная сеть
НДВ	–	не декларированные возможности
НЖМД	–	накопитель на жестких магнитных дисках
НСД	–	несанкционированный доступ
ОЗУ	–	оперативное запоминающее устройство
ОПО	–	общесистемное программное обеспечение
ОС	–	операционная система
ОТСС	–	основные технические средства и системы
ПДн	–	персональные данные
ПК	–	программный комплекс
ПО	–	программное обеспечение
ПС	–	программные средства
ПТС	–	программно-технические средства
ПЭВМ	–	персональная электронно-вычислительная машина
РД	–	руководящий документ
СВТ	–	средства вычислительной техники
СЗИ	–	система защиты информации
СКЗИ	–	средства криптографической защиты информации
СПО	–	специальное программное обеспечение
СрЗИ	–	средства защиты информации
ТЗ	–	техническое задание
ТС	–	технические средства
ТП	–	технический проект
ФСБ	–	Федеральная служба безопасности
ФСТЭК	–	Федеральная служба технического и экспортного контроля

3. Общие положения

Необходимостью создания ТЗКИ в ИСПДн «Кадровый учет» АО УК «Чистый дом» является обеспечение защиты информации при ее обработке в информационной системе.

СЗИ представляет собой совокупность организационных и технических мер, направленных на предотвращение неправомерного или случайного доступа к защищаемой информации, уничтожения, изменения, блокирования, копирования, распространения, а также иных неправомерных действий с ней.

Система защиты информации должна:

- защищать ИС от вмешательства посторонних лиц в процесс её функционирования (возможность использования ИС и доступ к её ресурсам должны иметь только зарегистрированные установленным порядком пользователи);

- предоставлять доступ конкретным пользователям ИС только к тем ресурсам ИС, к которым он необходим для выполнения своих служебных обязанностей, то есть защищать от несанкционированного доступа: к информации, обрабатываемой в ИС, средствам вычислительной техники, аппаратным и программным средствам защиты;

- регистрировать действия пользователей при использовании защищаемых ресурсов ИС в системных журналах и анализировать содержимое этих журналов с целью контроля корректности действий пользователей;
- контролировать целостность среды исполнения программ и ее восстановление в случае нарушения;
- защищать от несанкционированной модификации и контролировать целостность программных средств, а также обеспечить защиту системы от внедрения несанкционированных программ;
- защищать информацию, хранимую, обрабатываемую и передаваемую по каналам связи, от несанкционированного разглашения или искажения;
- своевременно выявлять источники угроз безопасности информации, причины и условия, способствующие их появлению, создавать механизмы оперативного реагирования на угрозы;
- создавать условия для минимизации наносимого ущерба неправомерными действиями физических и юридических лиц, уменьшать негативное влияние и ликвидировать последствия нарушения безопасности информации.

Для аналитического обоснования необходимости создания СЗИ использовалась Модель угроз безопасности информации для ИСПДн «Кадровый учет» АО УК «Чистый дом», разработанная на основании следующих документов:

- ГОСТ Р 51275-2006 Защита информации. Объект информатизации. Факторы, воздействующие на информацию;
- «Базовая модель угроз безопасности персональных данных при их обработке в информационных системах персональных данных», утвержденная Заместителем директора ФСТЭК России 15 февраля 2008 г;
- «Методика оценки угроз безопасности информации», утвержденная Заместителем директора ФСТЭК России 5 февраля 2021 г.

Для разработки модели угроз безопасности информации на договорной основе была привлечена организация - Закрытое акционерное общество «Центр безопасности информационных технологий» (ЗАО «ЦБИТ»), Регистрационный номер лицензии - Л024-00107-00/00583574 от 10.06.2016), совместно с начальником отдела по информационной безопасности (ИБ) АО УК «Чистый дом».

4. Описание систем и сетей и их характеристика как объектов защиты

Угрозы для ИСПДн «Кадровый учет» АО УК «Чистый дом» обусловлены преднамеренными или непреднамеренными действиями физических лиц или организациями (в том числе террористических), а также криминальных группировок, создающими условия (предпосылки) для нарушения безопасности персональных данных (ПДн), которые ведут к ущербу жизненно важным интересам личности, общества и государства.

ИСПДн «Кадровый учет» АО УК «Чистый дом» представлена в виде:

Персональные данные сотрудников организации:

- о фамилия, имя, отчество;
- о дата и место рождения;
- о пол;
- о сведения об образовании;
- о сведения о предыдущем месте работы;
- о адреса регистрации и фактического проживания;
- о номера контактных телефонов;
- о индивидуальный номер налогоплательщика;
- о номер страхового свидетельства пенсионного страхования;
- о номер полиса обязательного медицинского страхования;
- о данные водительского удостоверения.

В информационной системе одновременно обрабатываются данные 98 субъектов персональных данных (сотрудников) в пределах Организации.

4.1 Архитектура и схема подключений информационной системы

ИСПДн «Кадровый учет» АО УК «Чистый дом» представлена в виде:

- Три автоматизированных рабочих места (АРМ) пользователей, сетевой принтер, сервер, коммутационное оборудование.
- Топология: АРМ и сервер составляют сегмент корпоративной вычислительной сети (см. схему).

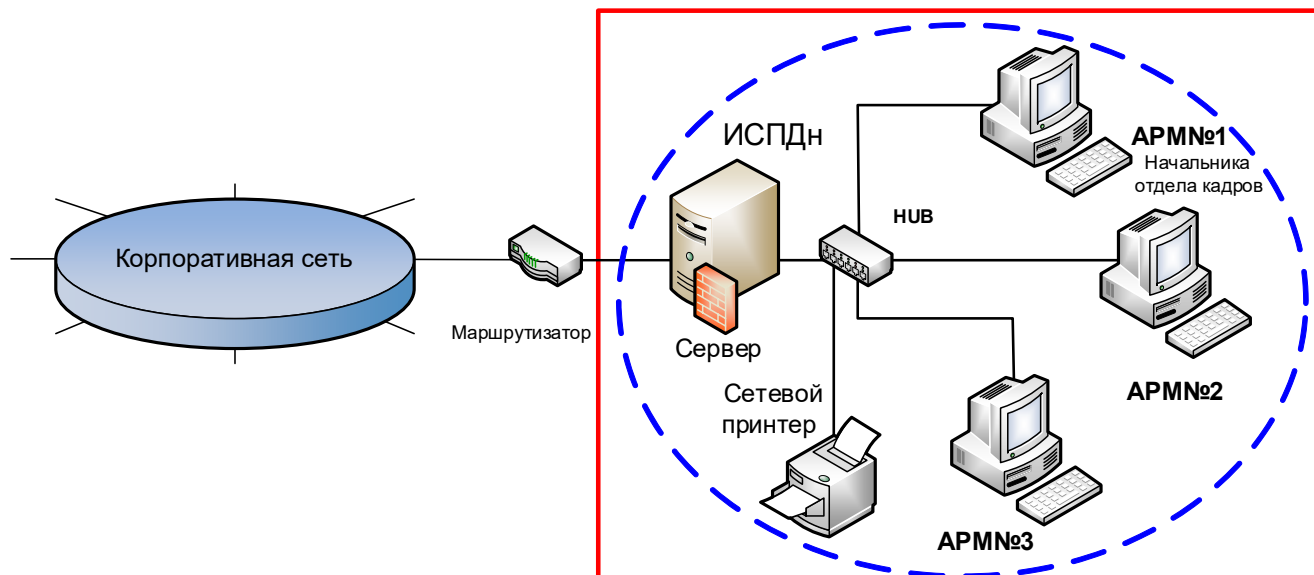


Схема ИСПД «Кадры» ЗАО «Солнышко»

Для передачи информации в ИСПДн «Кадровый учет» АО УК «Чистый дом» используется ЛВС, расположенная по адресу: РФ, г. Ростов-на-Дону, ул. Строителей, дом № 15, офис 306.

В процессе обработки персональных данных участвуют:

- сотрудники отдела кадров;
- заместитель директора.

В состав каждого АРМ входят два жёстких диска, на первом установлена операционная система, прикладное программное обеспечение и общедоступная справочная информация, на втором - информация, составляющая персональные данные сотрудников Организации.

1. Комплект АРМ № 1-3 (см. схему):

- системный блок CityTime № JFBNCGRHDBG01-03,
- монитор Samsung N710 – серийный номер KBMHDFGFD01-03,
- клавиатура Genius серийный номер WESDC01-03,
- графический манипулятор (мышь) Genius серийный номер DSDA01-03.

Состав ПО для обработки ПД:

- Клиентская часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОПП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

- Диспетчер печати.

2. В состав сервера входят три жестких диска, на первом установлена операционная система, прикладное программное обеспечение, второй и третий объединены в RAID массив, в котором хранится информация, составляющая персональные данные сотрудников Организации.

Комплект сервера:

- системный блок CityTime Prof № SDHBKYDHG04,
- монитор Samsung N710 – серийный номер JDHDNGHD04,
- клавиатура Genius серийный номер DGFU04,
- графический манипулятор Genius серийный номер HBDR04.

Состав ПО для обработки ПД:

- Серверная часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОРП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

2. Диспетчер печати.

Сервер и коммуникационное оборудование установлены в типовой стойке.

Сетевой принтер HP LaserJet P2015 серийный номер DEFVBG.

Коммутатор: Коммутатор Cisco WS-C2960CX-8TC-L.

Маршрутизатор: Маршрутизатор Cisco Small Business RV340-K8-RU.

4.2 Описание процессов передачи информации

Обработка персональных данных в ИСПДн «Кадровый учет» АО УК «Чистый дом» ведётся следующим образом:

К работе на АРМ допущены сотрудники отдела кадров и заместитель директора.

Полный доступ ко всей информации на АРМ и сервере имеют заместитель директора и начальник отдела кадров.

Сотрудники отдела кадров имеют полный доступ только к каталогу «Личные дела», размещённой на диске №2 своего АРМ, и только на чтение информации из каталога «Личные дела» на сервере.

Системный администратор сегмента сети не имеет доступа к информации, отнесенные к персональным данным. При администрировании сегмента сети системный администратор имеет права на установку, настройку программного обеспечения, программных (программно-аппаратных) средств защиты сервера и АРМ № 1-3.

Режим работы - одновременный.

4.3 Перечень программных средств, используемых для обработки персональных данных в ИСПДн «Кадровый учет» АО УК «Чистый дом»

Обработка персональных данных в ИСПДн «Кадровый учет» АО УК «Чистый дом» ведётся в специализированном программном обеспечении:

Состав ПО для обработки ПД в АРМ № 1-3:

1. Клиентская часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОРП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

2. Диспетчер печати.

Состав ПО для обработки ПД на сервере:

1. Серверная часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОРП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

2. Диспетчер печати.

Перечень имеющихся программных средств, используемых для обработки персональных данных приведены в таблице 1.

Таблица 1 – Перечень имеющихся программных средств (ПС), используемых для обработки персональных данных ИСПДн «Кадровый учет» АО УК «Чистый дом».

№ п/п	Наименование ПС (ее составной части)	Расположение объекта	Технология обработки (АРМ, ЛВС, Распр)	Субъекты ПДн	Объем обрабатываемых Пдн (количество записей субъектов Пдн в базе данных ИСПДн)	Описание режима работы с базой данных
1	«1С:Зарплата и кадры 8»	Клиентская часть	АРМ	сотрудники отдела кадров	98	Одновременно

				и заместитель директора		
2	«1С:Зарплата и кадры 8»	Серверная часть	АРМ	сотрудники отдела кадров и заместитель директора	98	Одновременно

4.4 Перечень структурных подразделений работающих с БД ПДн «Кадровый учет» АО УК «Чистый дом»

Перечень структурных подразделений работающих с БД ПДн «Кадровый учет» АО УК «Чистый дом» отображен в таблице 2.

Таблица 2 - Перечень структурных подразделений, работающих с БД ПДн «Кадровый учет» АО УК «Чистый дом»

№ п/п	Наименование БД (ее составной части)	Расположение объекта	Структурное подразделение
1	«Личные дела»	Сервер	Отдел кадров
2	«Личные дела»	диск №2 АРМ	Отдел кадров

4.5 Анализ организационных мер защиты ИСПДн

В ходе проведения проверки наличия и полноты методической и организационно-распорядительной документации прямо или косвенно относящейся к защите персональных данных было установлено, что документы по данной тематике не разрабатывались.

В зданиях, где находятся помещения ИСПДн «Кадровый учет» АО УК «Чистый дом», все двери помещений оборудованы врезными замками. Доступ в помещения, где расположены рабочие станции, ограничен, внедрена система контроля и управления доступом, войти могут только сотрудники.

Пожарная и охранная сигнализация установлена во всех помещениях, где обрабатываются персональные данные. Охрана объекта осуществляется частным охранным предприятием на договорной основе.

4.6 Анализ технологического процесса обработки информации, реализованного в информационной системе

Согласно представленному «Технологическому процессу обработки информации...» ИСПДн предназначена для обработки информации ограниченного доступа, формирования электронных документов (ЭД) и вывода их на печать. При этом информация в ИСПДн может поступать из других подразделений и организаций на учетных бумажных или электронных носителях информации.

Для осуществления технологического процесса обработки информации в ИСПДн используется программное обеспечение (ПО), перечисленное в таблице № 1.

ИСПДн «Кадры» ЗАО «Солнышко» предназначена для работы в одновременном режиме, доступ исполнителей к работе осуществляется по утвержденному списку, пользователи имеют ограничение права доступа к информации, ИСПДн не имеет подключения к сетям связи общего пользования и сетям международного информационного обмена.

Настройку систем защиты для конкретных пользователей и контроль ее работы осуществляет администратор безопасности информации. Функции, права, обязанности и порядок работы в ИСПДн администратора безопасности информации и пользователей регламентируются специально разработанными инструкциями администратору безопасности информации и пользователям.

Уровень подготовки администратора безопасности и пользователей позволяет выполнять возложенные на них обязанности.

4.8 Результаты классификации ИСПДн «Кадровый учет» АО УК «Чистый дом»

В соответствии с требованиями Постановления Правительства РФ от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных», выявлено, что тип актуальных угроз безопасности персональных данных АО УК «Чистый дом» относится к **угрозам 3 типа** – угрозы, не связанные с наличием недокументированных (недекларированных) возможностей в системном и прикладном программном обеспечении, используемом в информационной системе.

В соответствии с требованиями Приказа ФСТЭК России от 18.02.2013 г. № 21 «Об утверждении Составы и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» проведена классификация по уровням защищенности персональных данных при их обработке в ИСПДн «Кадры» ЗАО «Солнышко», таблица 3.

Таблица 3

№ п/п	Характеристика	Значение
1	Категория персональных данных	3
2	Субъекты ПДн	работники
3	Объем обрабатываемых ПДн	Менее 100 тыс.
4	Количество рабочих станций, входящих в состав ИСПДн	3
5	Структура ИСПДн	АРМ
6	Количество пользователей, допущенных к работе в ИСПДн	3
7	Режим обработки ПДн в ИСПДн	Многопользовательская ИСПДн с разными правами доступа
8	Разграничению прав доступа пользователей ⁷	С разграничением
9	Подключение ИСПДн к локальным (распределенным) сетям общего пользования	Имеется
10	Тип ИСПДн	Типовая
11	Местонахождение технических средств ИСПДн	Внутри КЗ
12	Тип актуальных угроз (на основании разработанной модели угроз и анализа актуальных угроз в ИСПДн)	3

По результатам анализа исходных данных информационной системы персональных данных, анализа актуальности угроз безопасности в разработанной модели угроз ИСПДн «Кадровый учет» АО УК «Чистый дом» присвоен **3 уровень защищенности**.

5. Возможные негативные последствия от реализации (возникновения) угроз безопасности информации

К основным негативным последствиям от реализации угроз безопасности ПД в ИСПДн «Кадровый учет» АО УК «Чистый дом» определены в таблице 4.

Таблица 4

№ п/п	Виды риска (ущерба)	Актуальность	Возможные типовые негативные последствия
У1	Ущерб физическому лицу	Возможны	Угроза жизни или здоровью. Унижение достоинства личности. Нарушение свободы, личной неприкосновенности.

			Нарушение неприкосновенности частной жизни.
			Нарушение личной, семейной тайны, утрата чести и доброго имени.
			Нарушение тайны переписки, телефонных переговоров, иных сообщений.
			Нарушение иных прав и свобод гражданина, закрепленных в Конституции Российской Федерации и федеральных законах.
			Финансовый, иной материальный ущерб физическому лицу.
			Нарушение конфиденциальности (утечка) персональных данных.
			Нарушение конфиденциальности (утечка) персональных данных.
			"Травля" гражданина в сети "Интернет".
			Разглашение персональных данных граждан
У2	Риски юридическому лицу, индивидуальному предпринимателю, связанные с хозяйственной деятельностью	Возможны	Нарушение законодательства Российской Федерации.
			Потеря (хищение) денежных средств.
			Недополучение ожидаемой (прогнозируемой) прибыли.
			Необходимость дополнительных (незапланированных) затрат на выплаты штрафов (неустоек) или компенсаций.
			Необходимость дополнительных (незапланированных) затрат на закупку товаров, работ или услуг (в том числе закупка программного обеспечения, технических средств, вышедших из строя, замена, настройка, ремонт указанных средств).
			Нарушение штатного режима функционирования автоматизированной системы управления и управляемого объекта и/или процесса.
			Срыв запланированной сделки с партнером.
			Необходимость дополнительных (незапланированных) затрат на восстановление деятельности.

6. Возможные объекты воздействия угроз безопасности информации

Негативные последствия, объекты воздействия, виды воздействия на них в ИСПДн «Кадровый учет» АО УК «Чистый дом» изображены в таблице 5.

Таблица 5

Негативные последствия	Объекты воздействия	Виды воздействия
Разглашение персональных данных граждан (У1)	База данных информационной системы, содержащая идентификационную информацию граждан	Утечка идентификационной информации граждан из базы данных
	Удаленное автоматизированное рабочее место (АРМ) пользователя	Утечка идентификационной информации граждан с АРМ пользователя
	Линия связи между сервером основного центра обработки данных и сервером резервного центра обработки данных	Перехват информации, содержащей идентификационную информацию граждан, передаваемой по линиям связи

	Веб-приложение информационной системы, обрабатывающей идентификационную информацию граждан	Несанкционированный доступ к идентификационной информации граждан, содержащейся в веб-приложении информационной системы
--	--	---

7. Источники угроз безопасности информации

Возможные цели реализации угроз безопасности ПД в ИСПДн «Кадровый учет» АО УК «Чистый дом» нарушителями представлены в таблице 6.

Таблица 6

№ вида	Виды нарушителя	Категории нарушителя	Возможные цели реализации угроз безопасности информации
1	Преступные группы (криминальные структуры)	Внешний	Получение финансовой или иной материальной выгоды.
			Желание самореализации (подтверждение статуса)
2	Авторизованные пользователи систем и сетей	Внутренний	Получение финансовой или иной материальной выгоды.
			Любопытство или желание самореализации (подтверждение статуса).
			Месть за ранее совершенные действия.
			Непреднамеренные, неосторожные или неквалифицированные действия

Уровни возможностей нарушителей по реализации угроз безопасности ПД в ИСПДн «Кадровый учет» АО УК «Чистый дом» представлена в таблице 7.

Таблица 7

№ п/п	Уровень возможностей нарушителей	Возможности нарушителей по реализации угроз безопасности информации	Виды нарушителей
1	Нарушитель, обладающий базовыми возможностями	Имеет возможность при реализации угроз безопасности информации использовать только известные уязвимости, скрипты и инструменты.	Физическое лицо (хакер)
		Имеет возможность использовать средства реализации угроз (инструменты), свободно распространяемые в сети "Интернет" и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов.	Лица, обеспечивающие поставку программных, программно-аппаратных средств, обеспечивающих систем
		Обладает базовыми компьютерными знаниями и навыками на уровне пользователя.	Лица, обеспечивающие функционирование систем и сетей или обеспечивающих систем (администрация, охрана, уборщики и т.д.)
		Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации, линий связи и обеспечивающие системы систем и сетей при наличии физического доступа к ним.	Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации, линий связи и обеспечивающие системы систем и сетей при наличии физического доступа к ним.

		Таким образом, нарушители с базовыми возможностями имеют возможность реализовывать только известные угрозы, направленные на известные (документированные) уязвимости, с использованием общедоступных инструментов	Бывшие работники (пользователи)
--	--	---	---------------------------------

8. Способы реализации (возникновения) угроз безопасности информации

Исходя из объектов воздействия и доступных интерфейсов, для каждого вида нарушителя определены актуальные способы реализации угроз безопасности ПД в ИСПДн «Кадровый учет» АО УК «Чистый дом» представлена в таблице 8.

Примеры определения актуальных способов реализации угроз безопасности информации и соответствующие им виды нарушителей и их возможности.

Таблица 8

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия	Доступные интерфейсы	Способы реализации
1	Разработчики программных, программно-аппаратных средств	Внешний	ПО	Удаленное подключение	внедрение дополнительных функциональных возможностей в программные или программно-аппаратные средства

9. Актуальные угрозы безопасности информации

Из общего состава техник и тактик, приведенных в Методике оценки угроз безопасности информации, утверждена ФСТЭК России от 5 февраля 2021 г., исключаем те, которые не связаны с используемыми технологиями, не применимы к процессам, не приводящие к ущербу или недоступные актуальным нарушителям. Все актуальные сценарии должны быть подмножествами их этого ограниченного набора тактик.

Перечень основных тактик и соответствующих им типовых техник, используемых для построения сценариев реализации угроз безопасности ПД в ИСПДн «Кадровый учет» АО УК «Чистый дом» представлена в таблице 9.

Таблица 9 – Расшифровка актуальных техник и тактик реализации УБИ

№ п/п	Тактика	Основные техники
1	Сбор информации о системах и сетях	T1.1. Сбор информации из публичных источников: официальный сайт (сайты) организации, СМИ, социальные сети, фотобанки, сайты поставщиков и вендоров, материалы конференций T1.3. Пассивный сбор (прослушивание) информации о подключенных к сети устройствах с целью идентификации сетевых служб, типов и версий ПО этих служб и в некоторых случаях - идентификационной информации пользователей
2	Получение первоначального доступа к компонентам систем и сетей	T2.1. Использование внешних сервисов организации в сетях

		публичного доступа (Интернет) Примеры: 1) доступ к веб-серверу, расположенному в сети организации; 2) доступ к интерфейсу электронной почты OutlookWebAccess (OWA) почтового сервера организации
--	--	--

Далее, исходя из этих применимых тактик, возможностей нарушителей, объектов воздействия и их интерфейсов и способов реализации определены актуальные угрозы (табл.10).

Таблица 10 – Перечень актуальных угроз безопасности информации в ИСПДн «Кадровый учет» АО УК «Чистый дом»

Группа актуальных угроз	Уровень возможностей нарушителей	Объекты воздействий	Способы реализации	Негативные последствия
Угрозы несанкционированной модификации защищаемой информации	H2	Прикладное программное обеспечение, Платежная\финансовая информация	C1,C10,C12	П2.2
Угрозы внесения несанкционированных изменений в прикладное программное обеспечение	H2	Прикладное программное обеспечение.	C1,C2,C10	П2.2
Угрозы сбора информации защищаемой системы	H2	АРМ клиента ФО, ПО клиентской части VPN или драйвера СКЗИ, Каналы связи, Системное программное обеспечение, Прикладное программное обеспечение	C1,C10,C12	П2.2
Угрозы ошибочных действий	H2	Прикладное программное обеспечение	C9	П2.2

10. ТСЗИ предлагаемые для использования ИСПДн

Так как, для обеспечения информационной безопасности организационных мер и встроенных средств недостаточно, следовательно, необходимо использовать дополнительные СЗИ, формирующие подсистемы СЗИ.

Все СЗИ должны организовывать полноценную систему защиты ПДн, обеспечивая полноценную защиту для конкретной ИСПДн.

Для реализации Комплексной системы ЗИ предлагается использовать следующие средства защиты информации, прошедшие процедуру оценки соответствия (сертифицированные СЗИ) ФСТЭК России, ФСБ России:

- средство защиты от НСД Dallas Lock 8.0-K, сертификат ФСТЭК России № 2720, действует до 25.09.2026;
- АПКШ «Континент» 4, сертификат ФСТЭК России № 4496, действует до 14.12.2026, сертификат ФСБ России № СФ/124-5237, действует до 20.08.2028;
- средство криптографической защиты информации «Континент TLS-сервер». Версия 2, сертификат ФСТЭК России № 4259, действует до 15.06.2029, сертификат ФСБ России № СФ/114-5391, действует до 01.01.2029;
- средство анализа защищенности XSpider 7.8.25, сертификат ФСТЭК России № 1525, действует до 15.06.2029;
- Антивирус Kaspersky Security для бизнеса, сертификат ФСТЭК России № 1525, действует до 15.06.2029.

11. Обоснование необходимости привлечения специальных организаций

В соответствии с подпунктом 5 пункта 1 статьи 12 Федерального закона от 4 мая 2011 г. № 99-ФЗ "О лицензировании отдельных видов деятельности" деятельность по созданию системы защиты информации должна осуществляться лицензиатом ФСТЭК России, имеющим лицензию ФСТЭК России на осуществление деятельности по технической защите конфиденциальной информации, включающую следующие виды работ и услуг:

☐ контроль защищенности конфиденциальной информации от несанкционированного доступа и ее модификации в средствах и системах информатизации;

☐ аттестационные испытания и аттестация на соответствие требованиям по защите информации:

- средств и систем информатизации;
- помещений со средствами (системами) информатизации, подлежащими защите;

☐ установка, монтаж, испытания, ремонт средств защиты информации:

- защищенных технических средств обработки информации;
- технических средств контроля эффективности мер защиты информации;
- программных (программно-технических) средств защиты информации;
- защищенных программных (программно-технических) средств обработки информации;

информации;

• программных (программно-технических) средств контроля защищенности информации).

Для реализации в ЗП мероприятий по технической защите информации у Заказчика отсутствует:

☐ необходимое контрольно-измерительное оборудование;

☐ лицензия на деятельность по технической защите конфиденциальной информации.

В связи с вышеизложенным целесообразно привлечение сотрудников специализированной организации, имеющей лицензии на деятельность по технической защите конфиденциальной информации.

12. Оценка материальных, трудовых и финансовых затрат на разработку и внедрение ТСЗИ

Ориентировочная стоимость предлагаемых к использованию сертифицированных средств защиты информации представлена в таблице 11.

Таблица 11 Ориентировочная стоимость предлагаемых технических средств

№ п/п	Продукт	Примерная стоимость, руб
1	Средство защиты от несанкционированного доступа на 3 рабочих места	71 000,0
2	Средство анализа защищенности	23 500,0
3	Средство межсетевого экранирования и криптографической защиты	89 500,0
	ИТОГО, руб.	184 000,0

К установке и настройке средств защиты информации могут привлекаться специалисты по защите информации оператора, разработчики информационной системы и сотрудников специализированной организации, имеющей лицензии на деятельность по технической защите конфиденциальной информации. Расчет стоимости работ по установке СЗИ приведен в таблице 12.

Таблица 12 – затраты работа на установку и настройки СрЗИ

№ п/п	Продукт	Примерная стоимость, руб
1	Установка и настройка средств защиты от несанкционированного доступа на 3 рабочих места 1 сервер	5 000,0
2	Установка и настройка средства анализа защищенности	5 000,0

3	Установка и настройка средства межсетевого экранирования и криптографической защиты	10 000,0
ИТОГО, руб.		20 000,0

Проведение испытаний системы защиты ИСПДн сопровождается выдачей документа, подтверждающего соответствие принятых мер защиты в соответствии с классом ИСПДн.

Проведение работ по оценке соответствия требованиям руководящих документов по защите ПДн в ИСПДн может проводить организация, имеющая лицензию на право проведения работ по защите конфиденциальной информации. Стоимость работ приведена в таблице 1.

Таблица 12 – Перечень работ по аттестации информационной систем

Продукт	Кол-во	Цена розничная, 1 шт., руб.	Общая стоимость, руб.
Предварительное обследование ИСПДн (изучение технологического процесса обработки и хранения защищаемой информации, анализ информационных потоков, определение состава использованных для обработки персональных данных средств)	1	20 000,0	20 000,0
Анализ исходных данных, необходимых для изучения и анализа циркулирующей информации.	1	10 000,0	10 000,0
Анализ организационной структуры ИС и условий ее эксплуатации, фиксация состава технических средств, входящих в аттестуемый объект, системы ЗИ на объекте, разработанной документации и её соответствия требованиям нормативной документации по ЗИ.	1	10 000,0	10 000,0
Разработка программы и методик аттестационных испытаний	1	15 000,0	15 000,0
Проверка состояния организации работ и выполнения организационно-технических требований по защите информации, оценка правильности классификации ИСПДн, оценка уровня разработки организационно-распорядительной, проектной и эксплуатационной документации, оценка уровня подготовки кадров и распределения ответственности за выполнение требований по обеспечению безопасности информации в ИСПДн.	1	20 000,0	20 000,0
Комплексные испытания на соответствие требованиям по защите от несанкционированного доступа (НСД) к информации, обрабатываемой в ИСПДн (за 1 АРМ)	3	2 500,0	7 500,0
Контрольные испытания ИСПДн на соответствие требованиям по защите информации от несанкционированного доступа в соответствии с определенным классом защищенности от НСД для межсетевого обмена	3	1 500,0	4 500,0
Подготовка отчетной документации (протоколы испытания и заключения по результатам аттестационных испытаний, аттестат соответствия	1	20 000,0	20 000,00
ИТОГО, руб.			137 000,00

13. Ориентировочные сроки разработки и внедрения ТСЗИ

Предпроектная стадия – разработка технического (частного технического) задания на создание системы защиты ИСПДн в течение десяти дней.

Стадия проектирования – разработка проектов, включающая разработку технического проекта СЗИ в составе ИСПДн в течение двадцати дней.

Стадия ввода в действие СЗИ – включает установку, настройку, опытную эксплуатацию и приемо-сдаточные испытания средств защиты информации, а также аттестацию объекта информатизации на соответствие требованиям безопасности информации в течение тридцати дней.

14. Перечень мероприятий по обеспечению конфиденциальности информации на стадии проектирования объекта информатизации

Настоящий раздел определяет состав, содержание и порядок выполнения мероприятий по обеспечению конфиденциальности информации на стадии проектирования объекта информатизации ИСПДн «Кадровый учет» АО УК «Чистый дом»).

Мероприятия по защите информации о создаваемой СЗИ ИСПДн «Кадровый учет» являются составной частью работ по ее созданию и осуществляются в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных», Постановления Правительства Российской Федерации от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных», Приказа ФСТЭК России от 18.02.2013 № 21 «Об утверждении Составы и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных», а также ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения».

Состав мероприятий по обеспечению конфиденциальности информации при проектировании ИСПДн «Кадровый учет»:

- Разработка замысла защиты информации о создаваемой ИСПДн «Кадровый учет».

В рамках данного мероприятия определяются цели и задачи защиты персональных данных, обрабатываемых в ИСПДн «Кадровый учет», устанавливаются принципы построения системы защиты информации (СЗИ) и предварительно определяется перечень организационных и технических мер защиты с учетом категории обрабатываемых персональных данных (иные персональные данные), количества субъектов персональных данных (сотрудников АО УК «Чистый дом») и условий обработки.

- Определение защищаемой информации о создаваемой ИСПДн «Кадровый учет».

На этом этапе формируется и документально закрепляется перечень сведений, составляющих персональные данные сотрудников АО УК «Чистый дом», подлежащих защите (фамилия, имя, отчество; дата и место рождения; пол; сведения об образовании; сведения о предыдущем месте работы; семейное положение; адреса регистрации и фактического проживания; номера контактных телефонов; ИНН; СНИЛС; номер полиса ОМС; данные водительского удостоверения и иные сведения, необходимые для кадрового учета). К защищаемой информации также относятся: цель и задачи защиты персональных данных в ИСПДн «Кадровый учет»; перечень составных частей (сегментов) ИСПДн, участвующих в обработке персональных данных (автоматизированные рабочие места, сервер, коммутационное оборудование); состав возможных уязвимостей и возможных последствий от реализации угроз безопасности персональных данных (нарушение конфиденциальности, целостности, доступности); структурно-функциональные характеристики ИСПДн (архитектура, состав, режимы обработки); меры и средства защиты информации, применяемые в ИСПДн; сведения о реализации системы защиты персональных данных.

- Определение носителей защищаемой информации о создаваемой ИСПДн «Кадровый учет», их уязвимостей и актуальных угроз безопасности персональных данных.

Для этого проводится инвентаризация машинных носителей (жесткие диски сервера и автоматизированных рабочих мест, съемные носители) и бумажных носителей, на которых будут храниться и обрабатываться персональные данные. Осуществляется анализ уязвимостей технических средств (системных блоков, мониторов, коммутаторов), программного обеспечения (операционная система, СУБД, прикладное программное обеспечение «1С:Зарплата и кадры») и архитектуры ИСПДн. Выявляются актуальные угрозы безопасности персональных данных с использованием Методики оценки угроз безопасности информации (ФСТЭК России, 05.02.2021) и Банка данных угроз ФСТЭК России. Определяется тип актуальных угроз (1-й, 2-й или 3-й) и на его основе – уровень защищенности персональных данных.

- Определение и технико-экономическое обоснование организационных и технических мероприятий, необходимых для защиты информации о создаваемой ИСПДн «Кадровый учет».

В составе мероприятия разрабатывается перечень организационных мер (назначение ответственных лиц за обеспечение безопасности персональных данных, разработка организационно-распорядительной документации, организация допуска сотрудников отдела кадров и заместителя директора к работе с персональными данными, инструктажи пользователей, организация контроля доступа в помещение и т.д.), а также перечень технических мер (выбор и обоснование сертифицированных средств защиты информации от несанкционированного доступа, антивирусной защиты, межсетевого экранирования, средств криптографической защиты информации при необходимости). Параллельно проводится оценка затрат на реализацию мероприятий и их эффективности.

Обоснование, разработка и/или закупка средств, необходимых для защиты информации о создаваемой ИСПДн «Кадровый учет».

Осуществляется выбор сертифицированных средств защиты информации (средств защиты от несанкционированного доступа, например, Dallas Lock 8.0-K или аналогичных, антивирусных средств, межсетевых экранов, средств криптографической защиты информации) из реестров ФСТЭК России. При отсутствии на рынке требуемых сертифицированных средств разрабатывается задание на создание собственных средств защиты информации с последующей сертификацией. Организуется закупка и поставка выбранных средств защиты информации для сервера и трех автоматизированных рабочих мест.

- Обоснование и разработка мероприятий по контролю состояния защиты информации о создаваемой ИСПДн «Кадровый учет».

На этом этапе разрабатываются программа и методика периодического контроля эффективности средств защиты информации, определяется порядок проведения внутренних проверок (не реже одного раза в год), инструментального контроля и анализа защищенности ИСПДн «Кадровый учет», а также устанавливается порядок действий при выявлении нарушений и недостатков.

- Разработка документов, регламентирующих организацию и осуществление защиты информации о создаваемой ИСПДн «Кадровый учет».

В рамках этого мероприятия разрабатываются и утверждаются организационно-распорядительные документы: приказ о назначении ответственных лиц за обеспечение безопасности персональных данных, приказ о допуске сотрудников к работе с ИСПДн «Кадровый учет», положение об обработке персональных данных, перечень сведений, составляющих персональные данные, инструкция пользователю (сотруднику отдела кадров и заместителю директора), инструкция администратору безопасности, программа и методика испытаний средств защиты информации, частное техническое задание на создание системы защиты персональных данных, а также модель угроз безопасности персональных данных.

Ответственность за организацию и обеспечение защиты информации о создаваемой ИСПДн «Кадровый учет» на стадии проектирования распределяется следующим образом:

- на стадиях «Формирование требований к информационной системе» и «Разработка концепции» – на заказчика (АО УК «Чистый дом») и разработчика (привлекаемую организацию-лицензиата);
- на стадии «Техническое задание» – на заказчика (АО УК «Чистый дом»);
- на стадиях «Эскизный проект», «Технический проект» и «Рабочая документация» – на разработчика информационной системы и системы защиты информации;
- на стадии «Ввод в действие» – на генерального конструктора (при его наличии) или руководителя проекта, а по частным вопросам – на изготовителей программных и технических средств;
- на стадии «Сопровождение работ» – на оператора ИСПДн «Кадровый учет» (АО УК «Чистый дом»).

При проектировании ИСПДн «Кадровый учет» должна быть организована разрешительная система доступа разработчиков, эксплуатирующего персонала (системного администратора, администратора безопасности), а при необходимости – и сотрудников сторонних организаций (поставщиков технических и программных средств, услуг по гарантийному обслуживанию, контролирующих органов) к защищаемой информации об ИСПДн, документации на ИСПДн, техническим и программным средствам, а также к

информационным ресурсам, содержащим персональные данные.

Общее руководство работами по защите информации при создании ИСПДн «Кадровый учет» осуществляет один из заместителей генерального директора АО УК «Чистый дом» (по информационным технологиям или по безопасности) или уполномоченное лицо.

В процессе создания (модернизации) ИСПДн «Кадровый учет» должен проводиться контроль состояния защиты информации, который заключается в оценке:

- соблюдения положений нормативных документов, устанавливающих требования безопасности персональных данных при создании ИСПДн;
- эффективности защиты информации о создаваемой ИСПДн «Кадровый учет»;
- знания исполнителями работ по созданию (модернизации) ИСПДн своих функциональных обязанностей в части защиты персональных данных.

В зависимости от характера нарушений, выявленных в процессе контроля, обработка информации в ИСПДн «Кадровый учет» может быть приостановлена до устранения причин нарушений.

Руководитель предпроектного обследования _____ И.О. Фамилия